Lab 37 — Cloud Shared Responsibility & IAM Least Privilege

The learner models the cloud shared-responsibility split, then enforces least privilege on a mock cloud IAM policy and detects an over-permissive grant.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Objective: Apply least privilege and read a shared-responsibility model

You'll build: A responsibility matrix (IaaS/PaaS/SaaS) and a tightened least-privilege JSON policy with the wildcard removed.

Tools: jq, policy JSON, bash

Step 1 — Create an over-permissive policy granting *:*

```
echo '{"Effect":"Allow","Action":"*","Resource":"*"}' > policy.json
```

Step 2 — Flag the wildcard as a finding

```
jq 'select(.Action=="*")' policy.json && echo "OVER-PERMISSIVE"
```

Step 3 — Rewrite it to least privilege (read one bucket)

```
echo '{"Effect":"Allow","Action":
["s3:GetObject"],"Resource":"arn:aws:s3:::reports/*"}' > policy.json
```

Step 4 — Confirm the wildcard is gone

```
jq -e '.Action|index("*")|not' policy.json && echo LEAST-PRIV
```

Step 5 — Map who secures what for IaaS/PaaS/SaaS

```
printf "IaaS: you=OS,app,data\nPaaS: you=app,data\nSaaS:
you=data,IAM\n"
```

Verify

The wildcard policy is flagged, and the rewritten policy scopes a single action to a single resource.